

VindobonaPay GmbH — DORA Compliance Mapping

Deliverable 05 | Regulation (EU) 2022/2554 | General ICT risk management framework (Art. 5-15) — authorised payment institution, not a microenterprise | Competent authority: FMA (Austria) | Version 2.0 | Fictional company for educational purposes

#	Article	Requirement	Applicability type	Implementation status	Supporting evidence (ISMS)	Gap / note	Action	Owner	Target
Pillar 1 — ICT risk management (Chapter II, Art. 5-15 — the Art. 16 simplified framework does not apply)									
DR-01	Art. 5	Management body defines, approves and oversees the ICT risk management framework, and keeps its ICT knowledge up to date.	Direct entity obligation	Partially implemented	A.5.4 management responsibilities; InfoSec Policy approved by management; management review meetings (Clauses 5.1, 9.3).	The framework is approved, but there is no structured ICT training for the management body and no record of it.	Deliver a yearly ICT risk briefing to the management body and keep attendance records.	CISO	Q4 2026
DR-02	Art. 6	Sound, documented ICT risk management framework, reviewed at least yearly, with a digital operational resilience strategy.	Direct entity obligation	Partially implemented	ISMS documentation; risk assessment methodology (Clause 6.1); Risk Register (Deliverable 01); SoA (Deliverable 02).	The ISMS covers the substance, but it is not yet presented as a DORA ICT risk framework with a documented resilience strategy.	Document the ICT risk management framework and the digital operational resilience strategy in DORA terms.	CISO	Q1 2027
DR-03	Art. 6(6)	The ICT risk framework is subject to internal audit by auditors with ICT expertise (entities other than microenterprises).	Direct entity obligation	Gap	Clause 9.2 internal audit programme defined; A.5.35 independent review planned; no internal audit performed yet.	No internal audit of the ICT risk framework has been carried out.	Schedule the first internal audit of the ICT risk framework with an auditor with ICT expertise.	Management	Q1 2027
DR-04	Art. 6(4)	Responsibility for managing and overseeing ICT risk is assigned to a control function with appropriate independence.	Direct entity obligation	Implemented	CISO role established in 2025, reporting to the CEO; roles and responsibilities documented (A.5.2, Clause 5.3).	No gap: the CISO function is separate from IT operations and reports to the CEO.	Maintain independence as the team grows; document the reporting line in the framework.	CEO	Ongoing
DR-05	Art. 7	ICT systems, protocols and tools are reliable, technologically resilient and appropriate to the scale of operations.	Direct entity obligation	Implemented	Azure platform with availability zones (A.8.14); capacity monitoring (A.8.6); Intune-managed endpoints (A.8.1).	No gap: infrastructure is proportionate to the size and criticality of the service.	Review capacity and architecture yearly against business growth.	CTO	Ongoing
DR-06	Art. 8	Identification of ICT-supported business functions, information assets and dependencies, including on ICT third parties.	Direct entity obligation	Partially implemented	Asset inventory (A.5.9); asset-based risk assessment; supplier list (partial).	Assets are inventoried, but critical or important functions are not formally identified and mapped to supporting assets and providers.	Identify critical or important functions and map them to assets and ICT providers.	CTO	Q4 2026
DR-07	Art. 9	Protection and prevention: security policies, identity and access management, encryption, network security, change management.	Direct entity obligation	Implemented	A.8.5 MFA and Conditional Access enforced for all users; A.8.3 RBAC; A.8.24 encryption; A.8.20-A.8.22 network security; A.8.32 change management.	No gap at framework level. Individual weaknesses (phishing-resistant MFA for privileged accounts, cloud hardening baselines) are tracked in the Risk Register and the SoA.	Close the open remediation actions already tracked in Deliverables 01 and 02.	IT Manager	Q4 2026
DR-08	Art. 10	Detection: mechanisms to promptly detect anomalous activities, with defined alert thresholds and criteria.	Direct entity obligation	Partially implemented	A.8.15 logging (partially centralized); A.8.16 monitoring; Defender for Endpoint alerts.	Log collection does not yet cover all payment platform components and alerting use cases are not fully defined.	Extend log coverage to all payment components and document alerting use cases and thresholds.	CISO	Q4 2026
DR-09	Art. 11	ICT business continuity policy, response and recovery plans, tested periodically.	Direct entity obligation	Partially implemented	A.5.29, A.5.30; BCP in draft; RTO/RPO defined; Incident Response Plan v1.1.	The Business Continuity Plan is still in draft and no ICT continuity test has been performed.	Approve the BCP and run the first ICT continuity test.	COO	Q4 2026
DR-10	Art. 12	Backup policies and procedures, restoration and recovery methods, with redundant capacity where required.	Direct entity obligation	Implemented	A.8.13 Azure Backup with periodic restore tests; A.8.14 redundancy across availability zones.	No gap: backups are automated and restore tests are documented.	Keep restore test records as evidence for supervisory review.	IT Manager	Ongoing
DR-11	Art. 13	Learning and evolving: post-incident reviews, ICT awareness programmes and training for staff.	Direct entity obligation	Partially implemented	A.5.27 post-incident reviews (informal); A.6.3 yearly awareness training and phishing simulations (Clauses 7.2, 7.3).	Staff training is in place; post-incident reviews are not yet formalized into a documented lessons-learned process.	Introduce a formal lessons-learned template feeding the ISMS improvement cycle (Clause 10.2).	CISO	Q3 2026
DR-12	Art. 14	Crisis communication plans for responsible disclosure of major incidents to clients, counterparts and the public.	Direct entity obligation	Gap	Incident Response Plan covers internal communication only (Clause 7.4).	No crisis communication plan for external disclosure to clients, counterparts or the public.	Define a crisis communication plan with roles, templates and approval path.	COO	Q1 2027
Pillar 2 — ICT-related incident management, classification and reporting (Chapter III, Art. 17-23)									
DR-13	Art. 17	ICT-related incident management process to detect, manage and notify incidents, with defined roles and procedures.	Direct entity obligation	Implemented	A.5.24-A.5.26; Incident Response Plan v1.1 with triage criteria and runbooks.	No gap: the internal incident process is documented and operational.	Align the plan wording with DORA terminology at the next review.	CISO	Q4 2026
DR-14	Art. 18	Classification of ICT-related incidents against the criteria set by the regulation and its technical standards.	Direct entity obligation	Gap	A.5.25 internal triage criteria defined by the organization.	Incidents are triaged internally but not classified against the regulatory criteria that determine whether an incident is major.	Add a regulatory classification step to the Incident Response Plan, based on the applicable technical standards.	Compliance Officer	Q1 2027
DR-15	Art. 19	Reporting of major ICT-related incidents to the competent authority: initial notification, intermediate report and final report.	Direct entity obligation	Gap	A.5.5 authority contact list (FMA, CERT.at); A.5.31 legal and regulatory register.	No documented reporting workflow: deadlines, templates, responsibilities and escalation path are not defined.	Define the regulatory reporting procedure for the FMA, with deadlines and named responsibilities.	Compliance Officer	Q1 2027
DR-16	Art. 23	Operational or security payment-related incidents are reported under the same regime (relevant for payment institutions).	Direct entity obligation	Gap	No dedicated procedure; payment incidents currently follow the general incident process.	Payment-related operational incidents are not separately identified in the reporting workflow.	Include payment-related incidents explicitly in the reporting procedure.	Compliance Officer	Q1 2027
Pillar 3 — Digital operational resilience testing (Chapter IV, Art. 24-27)									
DR-17	Art. 24	Digital operational resilience testing programme, proportionate to size and risk profile, as part of the ICT risk framework.	Direct entity obligation	Gap	A.8.29 security testing in development; yearly external penetration test.	Testing happens, but there is no documented testing programme covering systems supporting critical functions.	Define and approve a testing programme with scope, frequency and reporting.	CISO	Q1 2027
DR-18	Art. 25	Testing of ICT tools and systems: vulnerability assessments, scenario-based tests, penetration testing, at least yearly for critical systems.	Direct entity obligation	Partially implemented	Monthly vulnerability scans (A.8.8); SAST in the CI pipeline; yearly external penetration test.	Individual tests are performed, but they are not planned against critical functions or consolidated into test reports for supervisory review.	Map the test plan to critical functions and consolidate results into a yearly report.	Head of Engineering	Q1 2027
DR-19	Art. 26, 27	Advanced testing based on threat-led penetration testing (TLPT), for financial entities identified by the competent authority.	Conditional obligation	Not assessed	Not applicable under the current scenario: no TLPT designation has been assumed.	TLPT status: not currently designated. The obligation is conditional and would become applicable if the FMA identified the company under Art. 26. Selection criteria consider systemic impact, ICT risk profile and technology characteristics, not headcount alone.	Re-assess yearly, or immediately if the FMA designates the entity for TLPT.	Compliance Officer	Yearly review
Pillar 4 — Management of ICT third-party risk (Chapter V, Art. 28-30 — direct entity obligations. Art. 31-44 govern the designation and oversight of critical ICT third-party providers and are addressed to the ESAs, the Lead Overseer and the providers themselves: supervisory context, not assessed as obligations of VindobonaPay)									
DR-20	Art. 28	ICT third-party risk managed as part of the ICT risk framework, with a strategy and a designated responsibility.	Direct entity obligation	Partially implemented	A.5.19-A.5.22; supplier list with risk rating (partial); security clauses in main contracts.	Supplier management exists but is not structured as an ICT third-party risk strategy integrated into the framework.	Define the ICT third-party risk strategy and assign responsibility for monitoring arrangements.	Compliance Officer	Q1 2027
DR-21	Art. 28(3)	Register of information on all contractual arrangements with ICT third-party providers, maintained and reported to the authority.	Direct entity obligation	Gap	Supplier list exists internally; no register in the regulatory format.	No register of information in the format required for submission to the competent authority.	Build the register of information following the applicable implementing standard.	Compliance Officer	Q4 2026
DR-22	Art. 28(8)	Exit strategies for ICT services supporting critical or important functions.	Direct entity obligation	Gap	A.5.23 cloud exit planning mentioned in the Cloud Services Policy.	No documented exit strategy for the cloud services supporting the payment platform.	Document exit strategies for ICT services supporting critical functions.	CTO	Q1 2027
DR-23	Art. 29	Preliminary assessment of ICT concentration risk before entering into contractual arrangements.	Direct entity obligation	Gap	Not addressed: supplier assessment is per-supplier, not portfolio-level.	Dependency on a small number of providers (Microsoft for both collaboration and infrastructure) is not formally assessed.	Assess ICT concentration risk and document the conclusion in the supplier procedure.	Compliance Officer	Q1 2027
DR-24	Art. 30	Contractual arrangements include the provisions required by the regulation (access, audit, termination, subcontracting, service levels).	Direct entity obligation	Partially implemented	A.5.20 contract template with security, audit and breach notification clauses.	Existing clauses cover security and audit, but not the full set of provisions the regulation requires for critical functions.	Update contract templates and renegotiate contracts for services supporting critical functions.	Compliance Officer	Q1 2027
Pillar 5 — Information-sharing arrangements (Chapter VI, Art. 45)									
DR-25	Art. 45	Voluntary exchange of cyber threat information and intelligence within trusted communities.	Optional provision	Not assessed	A.5.6 contact with special interest groups (partial); A.5.7 ad-hoc threat monitoring.	Not a gap: participation in an information-sharing arrangement is optional under Art. 45. If VindobonaPay joined one, the applicable governance conditions and the obligation to notify the competent authority of entry into and exit from the arrangement would then be assessed.	Optional: consider joining a sector community (for example CERT.at or a financial-sector group); notify the FMA if an arrangement is entered into.	CISO	Optional

Applicability type

Direct entity obligation

Applies to VindobonaPay as written.

#	Article	Requirement	Applicability type	Implementation status	Supporting evidence (ISMS)	Gap / note	Action	Owner	Target
Conditional obligation			Applies only if a triggering condition occurs (for example designation by the competent authority).						
Optional provision			The regulation permits, but does not require, the activity.						
Supervisory context			Addressed to the ESAs, the Lead Overseer or ICT providers — included for completeness, not assessed as a compliance obligation.						
Not applicable			Outside the defined organizational scope.						

Implementation status

Implemented	Supported by controls assessed as fully implemented in the SoA.
Partially implemented	Supported by controls assessed as partially implemented.
Gap	No supporting control or process in place.
Not assessed	Conditional or optional provision not currently triggered or adopted.

Applicability: DORA applies since 17 January 2025. VindobonaPay is an authorised payment institution and not a microenterprise under Art. 3(60) — which covers an entity that employs fewer than 10 persons and has an annual turnover and/or annual balance-sheet total not exceeding EUR 2 million. It is therefore subject to the general ICT risk management framework of Articles 5 to 15, rather than the simplified framework of Article 16.

Proportionality is not an exemption from compliance. It affects both the applicable framework and how requirements are implemented, taking into account the entity's size, overall risk profile and the nature, scale and complexity of its activities.

Not every article of a regulation creates a direct obligation for every entity. Articles 31 to 44 govern the designation and oversight of critical ICT third-party service providers and are addressed to the ESAs, the Lead Overseer and the providers themselves. They are included as supervisory context and are not assessed as compliance obligations of VindobonaPay.

This is a high-level assessment against Regulation (EU) 2022/2554. It is NOT a complete DORA compliance assessment, because the regulatory and implementing technical standards have not been assessed requirement by requirement. Those standards specify much of the operational detail: incident classification thresholds, reporting templates, the format and content of the register of information, and the conduct of resilience testing.

Status decisions are consistent with the rest of the portfolio: a requirement supported only by controls marked 'Partially implemented' in the SoA (Deliverable 02) is not reported as implemented.

Source: EUR-Lex, Regulation (EU) 2022/2554. No regulatory text is reproduced: articles are referenced by number and described in my own words.

Priority actions — highest regulatory exposure first

Gaps ordered by supervisory visibility and dependency: reporting capability first, then third-party obligations, then testing.

Priority	Action	Requirements	Articles	Why it comes first	Owner	Target
1	Regulatory incident reporting procedure	DR-14, DR-15, DR-16	Art. 18, 19, 23	Without classification and reporting, a major incident would be handled internally but not notified within the deadlines. This is the most visible failure in a supervisory review.	Compliance Officer	Q1 2027
2	Register of information on ICT arrangements	DR-21	Art. 28(3)	The register is reported to the competent authority in a defined format; its absence is immediately verifiable.	Compliance Officer	Q4 2026
3	ICT third-party risk strategy, contracts and exit strategies	DR-20, DR-22, DR-23, DR-24	Art. 28, 29, 30	Contract renegotiation takes time and depends on providers, so it must start early even though the deadline is later.	Compliance Officer	Q1 2027
4	Digital operational resilience testing programme	DR-17, DR-18	Art. 24, 25	Testing already happens; what is missing is the programme that ties tests to critical functions and produces evidence.	CISO	Q1 2027
5	Internal audit of the ICT risk framework	DR-03	Art. 6(6)	Required for entities other than microenterprises and a prerequisite for demonstrating that the framework is reviewed independently.	Management	Q1 2027
6	Crisis communication plan	DR-12	Art. 14	Needed for responsible disclosure to clients and counterparts during a major incident.	COO	Q1 2027
7	ICT risk framework and resilience strategy documentation	DR-02, DR-06	Art. 6, 8	The substance exists in the ISMS; the work is presenting it in DORA terms and identifying critical functions.	CISO	Q1 2027

DORA Compliance Mapping — Summary

Version 2.0 — all values calculated automatically (COUNTIF) from the Mapping sheet.

Requirements assessed	25
-----------------------	----

BY APPLICABILITY TYPE	
Direct entity obligation	23
Conditional obligation	1
Optional provision	1
Supervisory context	0

BY IMPLEMENTATION STATUS	
Implemented	5
Partially implemented	9
Gap	9
Not assessed	2

BY PILLAR	Requirements	Open (Partial + Gap)
1 — ICT risk management	12	8
2 — Incident management & reporting	4	3
3 — Resilience testing	3	2
4 — ICT third-party risk	5	5
5 — Information sharing	1	0

Pillar 1 is largely supported by the existing ISMS, including the management-system clauses of ISO/IEC 27001 covering leadership, competence, monitoring, internal audit and management review. The open work concentrates in Pillars 2, 3 and 4 — the same areas rated 'No direct support' in Deliverable 03 and assessed as gaps in Deliverable 04.

Pillar 5 shows no open work because Article 45 is an optional enabling provision that VindobonaPay has not adopted: it is neither a gap nor a compliance achievement.

TLPT (Art. 26-27) is a conditional obligation. VindobonaPay is not currently designated by the FMA, so it is recorded rather than assessed — the status can change.